

Can we pilot this safely?

TL;DR — YES, IF

1. The pilot Streamlit URL uses DEMO DATA ONLY — no real supplier files uploaded · the password gate is rotated from the example in the repo · pilot CMs are told this in writing.
2. Real-data builds wait for the Wayfair-internal deployment in pilot week 2 (Wayfair SSO, EU residency, normal audit).

What the system handles

DATA CLASSIFICATION · PILOT VERSION

Allowed in pilot

- Storyboard names · brand palette
- Supplier names (Monty Trading, Forte UK, TuttiBambini)
- Demo metrics (already public artefacts on team Slack)
- Pilot password (hmac-compared, never logged)

Forbidden in pilot

- Real supplier CSVs (uploader is UI-only · no ingest)
- GRS · retail revenue · internal-only benchmarks
- Looker API calls · BigQuery queries
- Anthropic API calls (Build button is stubbed in v0.1)

Controls already in the code

- **Password gate** — hmac-compared shared secret · no bypass
- **HTTPS everywhere** — Streamlit Cloud terminates TLS · no plaintext
- **XSRF protection on** — config.toml flag · cookies signed, requests checked
- **Upload size capped** — 50MB · prevents DOS via huge files
- **File-type allowlist** — CSV / XLSX only · no executables, no archives
- **No telemetry** — gatherUsageStats = false · no Streamlit telemetry
- **Session isolation** — each CM's session state is independent · no leakage
- **Rule #1 enforced structurally** — supplier-facing audience locks GRS code path · unreachable

What we DON'T promise in pilot v0.1

- Streamlit Cloud is US-hosted (AWS) · not Wayfair-internal · pilot URL is demo only
- No formal pen-test on v0.1 · security review = pilot week 2 work
- No GDPR DPA on pilot URL · production version uses Wayfair existing infra contracts

Pre-greenlight checklist for platform team

- ☐ Pilot URL is not externally indexable · noindex set or app in private mode
- ☐ Pilot password rotated from the example value in secrets.toml.example
- ☐ Demo PPTX files reviewed as shareable demo assets (confirm with Faizan/Brian)
- ☐ Pilot CMs told in writing NOT to enter real supplier data on the URL
- ☐ Production deploy plan scoped for pilot week 2 (infra · SSO · platform contact)